Báo cáo Kiểm thử: Feature D (Pool D) — FR-02: Đăng nhập & Khóa tài khoản trên Mobile App

Học phần: Kiểm thử Phần mềm (FIT-HCMUS)
Bài tập: HW02 – Domain Testing & Boundary Value Analysis on EShop
Tính năng kiểm thử: `FR-02: Mobile Login and Account Lockout (React Native / Expo & Backend API)`
Kỹ thuật áp dụng: Phân hoạch tương đương (EP), Phân tích giá trị biên (BVA), Kiểm thử chuyển trạng thái & thời gian thực (State Transition & Time-dependent Testing)

---

1. Phân tích Đặc tả Yêu cầu & Xác định Biến trên Mobile

1.1 Căn cứ Đặc tả (SRS Ground Truth)

Theo tài liệu đặc tả hệ thống `EShop` (FR-02, FR-21, FR-22):

1. **Quy tắc Đăng nhập (`FR-02`):**
   - Người dùng nhập **Email** và **Mật khẩu**.
   - Đăng nhập thành công trả về JWT Token và điều hướng về trang chủ (`goHome()`). Đồng thời reset `login_attempts = 0` và `locked_until = NULL`.
2. **Cơ chế Khóa tài khoản (Account Lockout Policy):**
   - Sau mỗi lần đăng nhập sai, hệ thống tăng bộ đếm lên **đúng 1 đơn vị** ($login_attempts = login_attempts + 1$).
   - Nếu đăng nhập sai từ **3 lần trở lên liên tiếp** ($N \ge 3$), tài khoản bị tạm khóa **30 giây** (trong môi trường demo: $locked_until = now + 30s$).
   - Trong thời gian bị khóa, mọi nỗ lực đăng nhập đều bị từ chối với HTTP 403 Forbidden: "*Tài khoản đã bị khóa. Vui lòng thử lại sau.*".
   - Sau khi hết thời gian khóa ($now \ge locked_until$), người dùng được phép đăng nhập lại bình thường.
3. **Tiêu chuẩn Giao diện Di động (`FR-02`, `FR-21`, `FR-22`):**
   - Nhất quán ngôn ngữ tiếng Việt: Nút bấm phải là **"Đăng nhập"** (không dùng "Sign In").
   - Nhãn trường Email phải là **"Email"** (không dùng "Username") và có dấu `*` bên cạnh nhãn bắt buộc.
   - Trường Email trên Mobile phải hỗ trợ định dạng bàn phím điện tử `keyboardType="email-address"`.
   - Thông báo lỗi phải xuất hiện **phía trên** nút submit, không được nằm bên dưới.

1.2 Danh sách Biến Đầu vào, Biến Trạng thái & Đầu ra

Tên biến	Kiểu dữ liệu	Ý nghĩa	Ràng buộc nghiệp vụ
`email`	String	Địa chỉ email tài khoản	Bắt buộc, đúng định dạng, tồn tại trong CSDL
`password`	String	Mật khẩu tài khoản	Bắt buộc

Tên biến	Kiểu dữ liệu	Ý nghĩa	Ràng buộc nghiệp vụ
`login_attempts`	Integer	Số lần đăng nhập sai liên tiếp	Số nguyên không âm, ban đầu bằng 0
`locked_until`	DATETIME / String	Mốc thời gian kết thúc khóa	`NULL` hoặc Timestamp tương lai
`current_time`	DATETIME	Thời điểm gửi request đăng nhập	Thời gian thực (now)

Kết quả đầu ra kỳ vọng (Outputs):

- **Output 1 (Thành công - HTTP 200):** Cấp JWT Token, reset `login_attempts = 0`, điều hướng về Home.
- **Output 2 (Lỗi thông tin - HTTP 401):** Sai email hoặc mật khẩu, tăng đếm thêm đúng 1 đơn vị.
- **Output 3 (Tài khoản bị khóa - HTTP 403):** Báo tài khoản đã bị khóa, từ chối mọi yêu cầu đăng nhập.

---

2. Phân hoạch Lớp Tương đương (Equivalence Partitioning - EP)

Biến kiểm tra / Trạng thái	Mã lớp	Mô tả Lớp Tương Đương	Phân loại
Email (`email`)	**EC01**	Email hợp lệ và đã tồn tại trong CSDL	Valid
	EC02	Email chưa từng được đăng ký trong hệ thống	Invalid
	EC03	Để trống ô Email ($length = 0$)	Invalid
	EC04	Email sai định dạng cú pháp (thiếu `@`, domain)	Invalid
Mật khẩu (`password`)	**EC05**	Mật khẩu chính xác khớp 100% với tài khoản	Valid
	EC06	Mật khẩu sai (không khớp với tài khoản)	Invalid
	EC07	Để trống ô Mật khẩu ($length = 0$)	Invalid
Số lần sai (`attempts`)	**EC08**	Chưa từng sai hoặc sai dưới ngưỡng ($N < 3$, ví dụ: 0, 1, 2)	Valid
	EC09	Đạt ngưỡng khóa ($N \ge 3$, ví dụ: 3, 4)	Invalid
Thời gian khóa	**EC10**	Tài khoản không có mốc khóa (`locked_until == NULL`)	Valid
	EC11	Đang trong thời gian khóa ($now < locked_until$)	Invalid
	EC12	Đã hết thời gian khóa ($now \ge locked_until$)	Valid
Giao diện Mobile (GUI)	**EC13**	Tuân thủ tiếng Việt, nhãn có `*`, lỗi ở trên nút	Valid
	EC14	Dùng tiếng Anh "Sign In", nhãn "Username", lỗi ở dưới	Invalid

---

3. Phân tích Giá trị Biên (Boundary Value Analysis - BVA)

3.1 Biên Số Lần Sai (Ngưỡng Khóa $N = 3$)

- $N = 0$: Giá trị danh định ban đầu (Nominal).
- $N = 2$ ($Boundary - 1$): Điểm OFF — Chưa bị khóa.
- $N = 3$ ($Boundary$): Điểm ON — Bắt đầu bị khóa 30 giây.
- $N = 4$ ($Boundary + 1$): Điểm IN — Vùng đã bị khóa.

3.2 Biên Thời Gian Khóa (Ngưỡng $T = 30$ giây)

- $t_0 + 29s$ ($T - 1$): Điểm IN — Còn thời gian khóa, hệ thống PHẢI từ chối.
- $t_0 + 30s$ (T): Điểm ON — Vừa hết hạn khóa, cho phép xử lý lại.
- $t_0 + 31s$ ($T + 1$): Điểm OUT — Đã mở khóa hoàn toàn, đăng nhập thành công nếu đúng mật khẩu.

---

4. Ma Trận Chuyển Trạng Thái Khóa Tài Khoản

Trạng thái hiện tại	Sự kiện kích hoạt (Event)	Trạng thái kế tiếp	Hành động hệ thống
Bình thường ($N=0$)	Nhập đúng mật khẩu	**Bình thường ($N=0$)**	Đăng nhập thành công, cấp Token (HTTP 200).
Bình thường ($N=0$)	Nhập sai mật khẩu lần 1	**Cảnh báo ($N=1$)**	Tăng đếm $N=1$, HTTP 401.
Cảnh báo ($N=1$)	Nhập sai mật khẩu lần 2	**Cảnh báo ($N=2$)**	Tăng đếm $N=2$, HTTP 401.
Cảnh báo ($N=2$)	Nhập sai mật khẩu lần 3	**Bị khóa ($N=3, T=30s$)**	Tăng đếm $N=3$, gán $locked_until = now + 30s$, HTTP 403.
Cảnh báo ($N=1, 2$)	Nhập đúng mật khẩu	**Bình thường ($N=0$)**	Đăng nhập thành công, reset $N=0$.
Bị khóa ($T < 30s$)	Thử đăng nhập	**Bị khóa**	Từ chối ngay, HTTP 403.
Hết hạn khóa ($T \ge 30s$)	Nhập đúng mật khẩu	**Bình thường ($N=0$)**	Mở khóa, reset đếm về 0, HTTP 200.

---

5. Thiết kế Bộ Ca Kiểm thử & Kết quả Thực thi trên SUT

TC ID	Mục tiêu kiểm thử	Lớp / Điểm biên	Dữ liệu đầu vào (Test Data)	Kết quả kỳ vọng (Expected)	Kết quả thực tế trên SUT Live	Trạng thái
TC-MOB-01	Đăng nhập thành công lần đầu	EC01, EC05, BV-ATT-01	`test@eshop.com` / `Test1234!`	HTTP 200 OK, cấp JWT Token	Đăng nhập thành công, nhận token	**PASS**

TC ID	Mục tiêu kiểm thử	Lớp / Điểm biên	Dữ liệu đầu vào (Test Data)	Kết quả kỳ vọng (Expected)	Kết quả thực tế trên SUT Live	Trạng thái
TC-MOB-02	Đăng nhập sai lần 1 — Tăng đếm +1	EC06, EC08	`test@eshop.com` / `WrongPass1`	HTTP 401, `login_attempts = 1`	**LỖI:** Backend `server.js:54` cộng `+2` $\implies$ đếm thành 2!	**FAIL** (BUG-13)
TC-MOB-03	Đăng nhập sai lần 2 — Chưa khóa	EC06, EC08, BV-ATT-02	`test@eshop.com` / `WrongPass2`	HTTP 401, `login_attempts = 2`	**LỖI:** Do lần 1 đã là 2, lần 2 cộng tiếp 2 thành 4 $\implies$ **Bị khóa ngay lần sai thứ 2!**	**FAIL** (BUG-13)
TC-MOB-04	Đăng nhập đúng sau khi sai	EC05, EC08	`test@eshop.com` / `Test1234!`	HTTP 200 OK, reset `attempts = 0`	Đăng nhập thành công, reset bộ đếm về 0	**PASS**
TC-MOB-05	Khóa tài khoản đúng 30 giây	EC06, EC09, BV-ATT-03	Nhập sai liên tiếp để khóa	Khóa trong vòng **30 giây**	**LỖI:** Backend `server.js:57` gán `+180000ms` $\implies$ **Khóa 180s (3 phút)!**	**FAIL** (BUG-14)
TC-MOB-06	Thử đăng nhập khi đang khóa	EC11, BV-TIME-01	Mật khẩu đúng khi đang khóa	HTTP 403: Báo tài khoản bị khóa	Backend báo 403, nhưng Mobile App nuốt message, chỉ hiện lỗi chung	**FAIL** (BUG-15)
TC-MOB-07	Đăng nhập sau 31s (hết hạn khóa)	EC12, BV-TIME-04	Đợi 31s và đăng nhập đúng	Mở khóa thành công sau 30s	**LỖI:** Sau 31s vẫn bị khóa vì backend cài khóa 180s!	**FAIL** (BUG-14)
TC-MOB-08	Kiểm tra nhãn Email và dấu *	EC13, EC14, FR-22	Màn hình Đăng nhập Mobile	Nhãn "Email *"	**LỖI:** Nhãn hiển thị là `"Username"`, không có dấu *	**FAIL** (BUG-15)
TC-MOB-09	Kiểm tra nhãn nút bấm Đăng nhập	EC13, EC14, FR-21	Nút Submit trên Mobile	Nhãn "Đăng nhập" tiếng Việt	**LỖI:** Nút bấm dùng tiếng Anh `"Sign In"`	**FAIL** (BUG-15)
TC-MOB-10	Kiểm tra vị trí thông báo lỗi	EC13, EC14, FR-22	Kích hoạt thông báo lỗi	Lỗi hiển thị **phía trên** nút submit	**LỖI:** Thông báo lỗi đặt ở cuối trang, **dưới cả nút bấm**	**FAIL** (BUG-15)

6. Phân tích Thiếu sót của AI (AI Gap Analysis)

6.1 Những điểm AI bỏ sót hoặc dự đoán sai:

1. **Bỏ sót lỗi logic gia tăng bộ đếm (`BUG-13` — Tăng `+2`):** AI mặc định suy luận mỗi lần thất bại biến đếm sẽ tăng 1 (`attempts++`). Thực tế backend viết `login_attempts + 2` khiến tài khoản bị khóa oan ngay lần sai thứ 2.
2. **Dự đoán sai về thời gian hết hạn khóa (`BUG-14` — 180s vs 30s):** AI đọc đặc tả thấy "30 giây" nên giả định hệ thống mở khóa sau 30s, bỏ qua việc giá trị `180000` trong code tương đương 3 phút (180 giây).
3. **Bỏ sót các vi phạm giao diện di động (`BUG-15`):** AI bỏ qua nhãn "Username", nút tiếng Anh "Sign In" và vị trí hộp lỗi nằm dưới nút bấm.

6.2 Giải thích nguyên nhân cốt lõi (Root Causes):

- **Prompt:** Prompt cơ bản không yêu cầu kiểm thử chuyển trạng thái (State Transition) và thời gian thực (Time-dependent).
- **Giới hạn AI:** AI là mô hình phi trạng thái (Stateless), không có đồng hồ thực tế để "chờ 30 giây" kiểm chứng.
- **Hệ thống SUT:** Sự kết hợp giữa bộ đếm CSDL, ISO timestamp và logic render di động là bài toán đa chiều cần kiểm thử viên con người dẫn dắt.

6.3 Bài học kinh nghiệm:

- Với hệ thống có trạng thái, bắt buộc phải kiểm tra từng bước chuyển tiếp ($N=1, N=2$), không nhảy cóc.
- Luôn quy đổi đơn vị thời gian từ code (miligiây) ra đặc tả (giây/phút) để phát hiện sai lệch.

---

7. Đoạn văn Phản biện (AI Critique)

Kiểm thử tính năng Đăng nhập & Khóa tài khoản trên Mobile App (FR-02) đã làm bộc lộ rõ rệt giới hạn bản chất của trí tuệ nhân tạo đối với các bài toán kiểm thử phụ thuộc trạng thái (State-dependent) và thời gian thực (Time-dependent). Trong khi AI dễ dàng thỏa mãn với kịch bản bề nổi—thấy tài khoản bị khóa sau khi đăng nhập sai thì vội vàng kết luận hệ thống hoạt động đúng—thì kiểm thử viên con người với phương pháp luận Phân tích Giá trị Biên (BVA) nghiêm ngặt của FIT-HCMUS đã tỉ mỉ kiểm tra từng nấc thang chuyển trạng thái ($N=1, N=2$). Chính sự cẩn trọng này đã vạch trần hai khuyết tật logic chí mạng: bộ đếm bị nhảy cóc `+2` khiến người dùng bị khóa oan uổng chỉ sau 2 lần sai, và thời gian khóa bị kéo dài tới 180 giây thay vì 30 giây theo đặc tả. Trí tuệ nhân tạo không thể tự cảm nhận được thời gian trôi qua, không thể nhìn thấu sự bất hợp lý của một nút bấm 'Sign In' trên giao diện thuần Việt, và càng không thể thay thế óc quan sát sắc sảo của con người. Điều này tái khẳng định rằng: AI chỉ phát huy được giá trị khi được đặt dưới sự dẫn dắt chiến lược và tư duy kiểm định nghiêm cẩn của kiểm thử viên con người.

---

8. Minh Chứng Kiểm Thử Chuẩn Hóa (Defect Evidence)

Mã Bug	Tóm tắt Khuyết tật	Minh chứng Mã nguồn (Code Card)	Minh chứng Thực tế (UI / CSDL)

Mã Bug	Tóm tắt Khuyết tật	Minh chứng Mã nguồn (Code Card)	Minh chứng Thực tế (UI / CSDL)
BUG-13	Bộ đếm sai tăng +2 mỗi lần (server.js:54)	[screenshots/F02/BUG-FR02-01_Code.png] (file:///d:/KAN/N4_1/KTPM-2026-HW02-Domain-Testing/screenshots/F02/BUG-FR02-01_Code.png)	[screenshots/F02/BUG-FR02-01_DB.png] (file:///d:/KAN/N4_1/KTPM-2026-HW02-Domain-Testing/screenshots/F02/BUG-FR02-01_DB.png)
BUG-14	Khóa tài khoản 180s thay vì 30s (server.js:57)	[screenshots/F02/BUG-FR02-02_Code.png] (file:///d:/KAN/N4_1/KTPM-2026-HW02-Domain-Testing/screenshots/F02/BUG-FR02-02_Code.png)	[screenshots/F02/BUG-FR02-02_DB.png] (file:///d:/KAN/N4_1/KTPM-2026-HW02-Domain-Testing/screenshots/F02/BUG-FR02-02_DB.png)
BUG-15	Vi phạm tiêu chuẩn giao diện di động FR-21 / FR-22	[screenshots/F02/BUG-FR02-03_Code.png] (file:///d:/KAN/N4_1/KTPM-2026-HW02-Domain-Testing/screenshots/F02/BUG-FR02-03_Code.png)	[screenshots/F02/BUG-FR02-03_UI.png] (file:///d:/KAN/N4_1/KTPM-2026-HW02-Domain-Testing/screenshots/F02/BUG-FR02-03_UI.png)